UNIVERSITY OF THE PEOPLE

CS 2301-01 - AY2027-T1

Unit 7 Assignment

Submitted by: Mubashir Ali

Instructor: Joseph Ego

Date: October 15, 2026

Strengthening Healthcare Cybersecurity Against Malware and Ransomware Attacks

Introduction

Healthcare organizations depend on operating systems, electronic health records (EHRs), laboratory systems, medical devices, and hospital networks to provide safe and timely patient care. These systems store highly sensitive information, including medical histories, prescriptions, diagnostic results, and personal details. A malware attack can therefore threaten not only information security but also patient safety and hospital operations. In the given scenario, attackers used phishing emails and ransomware to gain unauthorized access to patient data and disrupt healthcare services. Hailperin (2019) explains that operating systems and middleware provide security features, but weaknesses in their design, configuration, or use can create opportunities for attackers. This paper examines the malware involved, recommends access control strategies and security policies, and explains how encryption and other cryptographic methods can strengthen healthcare security.

1. Malware Types and Their Effects on Healthcare Data Integrity

At least three types of malicious software could be involved in this incident: ransomware, spyware or information-stealing malware, and a Trojan or other malware delivered through phishing. These threats can work together to compromise patient information and hospital operations.

Ransomware

Ransomware is a malware that encrypts files or otherwise prevents an organization from accessing its data until the attackers demand payment. In a hospital, ransomware may affect electronic health records, appointment systems, laboratory results, billing databases, and systems used to coordinate patient care. When authorized healthcare professionals cannot access accurate medical records, treatment may be delayed, and staff may need to use less efficient manual procedures.

Ransomware commonly exploits unpatched software, exposed remote access services, weak credentials, or excessive user privileges. An attacker may first obtain access through a phishing email and then move across the network to reach additional systems. If the compromised account has permission to modify shared records or access backups, the impact can spread throughout the organization. Encryption by ransomware primarily threatens data availability, while unauthorized modifications or deletion can also threaten data integrity. These consequences demonstrate why healthcare organizations need effective prevention and recovery mechanisms (National Institute of Standards and Technology [NIST], n.d.-a).

Spyware and Information-Stealing Malware

Spyware secretly collects information from a computer or network. Related information-stealing malware may capture login credentials, session tokens, or other sensitive information. Attackers could use stolen employee credentials to enter patient databases, download medical records, or access administrative systems without permission.

This threat is particularly serious when employees reuse passwords or when a compromised account has broad access to patient information. Although data theft does not necessarily modify the original records, it violates confidentiality and may enable subsequent unauthorized changes. For example, an attacker who obtains a clinician's credentials might alter a patient's prescription or interfere with a medical record. Such unauthorized modifications directly threaten data integrity.

Trojan Malware and Phishing-Based Delivery

A Trojan is malicious software disguised as a legitimate application, document, or file. Phishing emails may persuade employees to open malicious attachments, click deceptive links, or enter their credentials on fraudulent websites. A malicious download may then install a Trojan or another payload that gives attackers a foothold in the hospital network.

Once installed, the malware may establish unauthorized remote access, download additional malicious programs, or allow attackers to explore connected systems. Unpatched applications, weak email filtering, inadequate endpoint protection, and insufficient employee awareness can increase the likelihood of a successful attack. The

U.S. Department of Health and Human Services (HHS, n.d.-a) identifies phishing and ransomware as important cybersecurity risks for healthcare organizations.

These malware types may form stages of a coordinated attack rather than operate independently. Phishing can provide the initial entry point, information-stealing malware can expose credentials, and ransomware can subsequently encrypt important files. Effective protection must therefore address the entire attack process instead of relying on a single antivirus program.

2. Access Control Strategies and Security Policies

The healthcare organization should implement multiple layers of protection to reduce unauthorized access and limit the damage caused by compromised accounts.

Role-Based Access Control and Least Privilege

Role-based access control (RBAC) assigns permissions according to employees' responsibilities. For example, physicians may need access to clinical records; billing staff may require access to payment information, and IT administrators may need technical privileges. Employees should not automatically receive access to every hospital database.

The organization should also enforce the principle of least privilege, which means granting users only the permissions necessary to perform their duties. Standard employee accounts should not have administrative privileges unless required. Separate administrator accounts should be used for administrative tasks, and privileged access should receive additional monitoring. These controls limit the number of systems an attacker can compromise after stealing one employee's credentials.

Multifactor Authentication and Account Management

Multifactor authentication (MFA) requires users to verify their identities through more than one authentication factor. The hospital should require MFA for remote access, email, cloud services, and privileged accounts. Strong authentication reduces the risk that a stolen password alone will provide access to sensitive systems.

Accounts should be disabled promptly when employees leave or change roles. The organization should also review service accounts, remove unnecessary accounts, and prohibit shared administrative credentials wherever possible.

Regular Security Audits

The hospital should conduct periodic access reviews, vulnerability assessments, configuration checks, and penetration tests. Audits should identify excessive permissions, inactive accounts, outdated software, insecure network configurations, and weaknesses in backup protection. Critical vulnerabilities should be prioritized according to their severity and potential effect on patient care.

Audit findings should be documented, assigned to responsible staff, and tracked until corrective actions are completed. The organization should also verify that its security controls continue to work as intended.

Employee Training and Security Monitoring

Employees should receive cybersecurity training during onboarding and at regular intervals. Training should cover phishing recognition, suspicious attachments, password protection, MFA, safe handling of patient data, and procedures for reporting suspected incidents. Simulated phishing exercises can help evaluate whether training is effective.

The hospital should deploy centralized security logging, endpoint detection and response, and a security information and event management system (SIEM). These tools can help identify unusual login attempts, unauthorized privilege changes, unexpected access to patient records, and suspicious file encryption. Automated alerts should be reviewed by trained personnel, with a defined escalation procedure for serious events.

Finally, the organization should maintain an incident response plan, isolate infected systems quickly, and keep encrypted or otherwise securely protected backups that are separated from ordinary network access. Backups should be tested regularly to confirm that patient records and critical services can be restored. HHS (n.d.-b) recommends healthcare-specific cybersecurity practices that strengthen protection, detection, response, and recovery.

3. Encryption, Cryptography, and Ransomware Risk Reduction

Encryption is a cryptographic technique that converts readable information, known as plaintext, into unreadable ciphertext using an algorithm and a key. Authorized users can recover the information through the appropriate decryption process. Cryptography is the broader field that includes encryption, digital signatures, cryptographic hashes, and message authentication codes. Therefore, encryption is one component of cryptography rather than a separate alternative to it (NIST, n.d.-b).

How Encryption Helps Healthcare Organizations

The hospital should encrypt patient records stored in databases, servers, laptops, mobile devices, and backups. It should also use modern, secure protocols to protect data transmitted between healthcare facilities, medical devices, and authorized users. Encryption can reduce the risk of exposing readable patient information if a device is stolen or an unauthorized party intercepts network traffic.

However, encryption alone does not prevent ransomware. If attackers gain access to an authorized user's account or compromise a running system, they may be able to encrypt files that the account can modify, even when those files were already encrypted at rest. Encryption also cannot guarantee that an authorized user or compromised application will not alter medical records. Consequently, the hospital must combine encryption with least-privilege access, endpoint protection, network segmentation, reliable backups, and incident response procedures.

Modern Encryption and Traditional Cryptographic Methods

Traditional cryptographic methods often included manual substitution or transposition ciphers. These methods may be useful for understanding cryptographic principles, but simple historical ciphers are unsuitable for protecting modern healthcare records because they do not provide adequate security against contemporary attacks.

Modern encryption uses established algorithms and carefully managed cryptographic keys. For example, AES is a widely used symmetric encryption algorithm that can protect large volumes of stored data. Modern public-key cryptography can support secure key establishment and other security functions. Properly configured protocols can protect information while it travels across networks.

Other cryptographic mechanisms provide different protections. Cryptographic hashes can help detect changes to data when used in a properly designed verification process. Message authentication codes can help verify data integrity and authenticity between parties that share a secret key. Digital signatures can help establish the origin and integrity of signed records (NIST, n.d.-c). These mechanisms complement encryption but do not all perform the same function.

The organization should use current, vetted cryptographic standards rather than inventing its own algorithms. It should also protect encryption keys separately from the data they secure, restrict access to those keys, rotate them when appropriate, and maintain tested recovery procedures. If attackers obtain the keys or control the system while data is being used, encryption may offer less protection than expected.

Conclusion

The healthcare organization's incident demonstrates how phishing, credential theft, and ransomware can combine to expose sensitive information, damage data integrity, and interrupt patient care. Ransomware can make records unavailable, spyware can steal credentials, and Trojan malware can establish unauthorized access. To reduce these risks, the hospital should enforce role-based access control, least privilege, multifactor authentication, regular audits, employee training, and continuous security monitoring. Modern encryption can protect patient information at rest and in transit, while hashes, message authentication codes, and digital signatures can provide additional integrity and authenticity protections. Because no single mechanism can stop every attack, the most effective approach combines technical safeguards, responsible security policies, tested backups, and a well-practiced incident response plan.

References

Hailperin, M. (2019). *Operating systems and middleware: Supporting controlled interaction* (Rev. ed. 1.3.1). Gustavus Adolphus College. https://www.cs.utexas.edu/~ans/classes/cs439/osm-rev1.3.1.pdf

National Institute of Standards and Technology. (n.d.-a). *Ransomware protection and response*. https://csrc.nist.gov/Projects/ransomware-protection-and-response

National Institute of Standards and Technology. (n.d.-b). *Cryptography*. https://www.nist.gov/cryptography

National Institute of Standards and Technology. (n.d.-c). *Digital signatures*. https://csrc.nist.gov/Projects/Digital-Signatures

U.S. Department of Health and Human Services. (n.d.-a). *Health industry cybersecurity practices*. HHS Cyber Gateway. https://hhscyber.hhs.gov/cornerstone-hicp.html

U.S. Department of Health and Human Services. (n.d.-b). *Cybersecurity performance goals*. HHS Cyber Gateway. https://hhscyber.hhs.gov/cornerstone.html